



Verantwortlichkeiten des Verantwortlichen

Die Organisation, die für die Verarbeitung verantwortlich ist, muss geeignete technische und organisatorische Maßnahmen ergreifen, um ein dem Risiko angemessenes Sicherheitsniveau zu gewährleisten. Dazu gehören Mittel, die die Vertraulichkeit, Integrität und Verfügbarkeit der vorhandenen IT-Systeme gewährleisten können. Sie muss auch Mittel einsetzen, um die Verfügbarkeit personenbezogener Daten im Falle eines Vorfalls wiederherzustellen (Artikel 32 DSGVO).

Im Falle einer Verletzung des Schutzes personenbezogener Daten ist der Verantwortliche gemäß Artikel 33 DSGVO verpflichtet, die CNPD zu benachrichtigen. Das Formular zur Benachrichtigung über Datenschutzverletzungen kann von der CNPD-Website heruntergeladen und an die E-Mail-Adresse databreach@cnpd.lu gesendet werden.

Wie kann man einen Angriff vereiteln?

Technische und organisatorische Maßnahmen, die ergriffen werden müssen, um das Risiko von Ransomware zu verringern:

- **Sensibilisierung der Nutzer:** Menschliches Versagen ist nach wie vor ein wichtiger Faktor bei Datenschutzverletzungen. Meistens beginnt der Ransomware-Angriff mit dem Öffnen eines mit Malware versehenen Anhangs oder dem Anzeigen einer schädlichen Webseite. Daher ist die Schulung der Nutzer in guten digitalen Sicherheitspraktiken ein grundlegender Schritt zur Bekämpfung dieser Bedrohung.
- **Einrichtung einer dedizierten Kontaktstelle:** Benennen Sie eine oder mehrere Personen, die die Nutzer des IT-Systems bei Verdacht auf einen Sicherheitsvorfall benachrichtigen müssen. Diese Kontaktstelle muss jederzeit erreichbar sein und jeder Nutzer muss wissen, wie er mit dieser (diesen) Person(en) in Kontakt treten kann.
- **Verlangen Sie starke und einzigartige Passwörter:** Alle Benutzerkonten müssen durch starke und einzigartige Passwörter geschützt werden. Auch die Zwei-Faktor-Authentifizierung (2FA) wird empfohlen, insbesondere für den externen Zugriff sowie für den Zugriff auf kritische Maschinen der IT-Umgebung (z.B. Domänencontroller)



- **Daten speicher:** Regelmäßige Sicherungen aller Daten, einschließlich solcher auf kritischen Datei-, Infrastruktur- und Geschäftsanwendungsservern, sind durchzuführen. Diese Backups, zumindest was die kritischsten betrifft, müssen vom Informationssystem getrennt werden, um ihre Verschlüsselung durch die Ransomware zu verhindern. Die Verwendung von Cold-Storage-Lösungen wie externen Festplatten oder Magnetbändern schützt Backups vor Systeminfektionen und hält kritische Daten für die Wiederherstellung bereit
- **Software und Systeme auf dem neuesten Stand halten:** Vorhandene ungepatchte Schwachstellen von Betriebssystemen oder Software können verwendet werden, um das System zu infizieren oder die Ausbreitung von Infektionen zu fördern. Es ist wichtig, die verfügbaren Updates (einschließlich Sicherheitspatches) so schnell wie möglich zu installieren.
- **Verwenden und Warten von Antivirensoftware:** Obwohl Antivirenprogramme keinen Schutz vor bisher unbekannter Ransomware garantieren, ist die Verwendung dieser Tools auf exponierten Stellen (Workstations, Dateiservern usw.) immer noch erforderlich. Damit diese Tools wirksam sind, ist es wichtig, häufige Aktualisierungen durchzuführen und regelmäßig sicherzustellen, dass keine bekannte Malware auf den Dateispeicherplätzen des Unternehmens vorhanden ist.
- **Segmentierung des Informationssystems:** Ohne eine Schutzmaßnahme und von einem einzigen infizierten Computer aus kann sich Ransomware über Ihr gesamtes Informationssystem ausbreiten und die meisten zugänglichen Maschinen infizieren. Um das Ausbreitungsrisiko zu begrenzen, sollte das Informationssystem in Zonen unterteilt werden, die jeweils ein homogenes Sicherheitsniveau aufweisen (z. B. interner Serverbereich, internetexponierter Serverbereich, Benutzerarbeitsplatzbereich, Verwaltungsbereich usw.).
- **Benutzerrechte und Anwendungsberechtigungen einschränken:** Benutzer dürfen keine Administratoren ihrer Workstation sein. Dies schränkt die Möglichkeit der Softwareinstallation und der unbeabsichtigten Ausführung von Schadcode ein. Darüber hinaus muss eine regelmäßige Überprüfung dieser Nutzer und ihrer Rechte durchgeführt werden, um sicherzustellen, dass dies den tatsächlichen Bedürfnissen der Organisation (Austritt von Mitarbeitern, Arbeitsplatzwechsel usw.) entspricht.
- **Verschlüsselungssoftware einrichten:** Die Implementierung von Verschlüsselungstechnologien ist eine zusätzliche Sicherheitsmaßnahme zum Schutz Ihrer gespeicherten Daten. Selbst wenn es Kriminellen gelingt, Ihre Daten zu stehlen, können sie nicht auf sie zugreifen oder sie offenlegen (vorausgesetzt, dass die Verschlüsselungs- / Entschlüsselungsschlüssel nicht kompromittiert werden).
- **Verbesserung der IT-Sicherheit beim Homeoffice:** Wenn die Mitarbeiter Ihres Unternehmens Anspruch auf Homeoffice haben, ist es wichtig, professionelle und persönliche Werkzeuge getrennt zu halten. Wenn Ihr Unternehmen einen Computer mit sicherem Zugriff, Firewalls und anderen Antivirenprogrammen eingerichtet hat, sollten nur



Merkblatt 9:

Sicherheitstechnische und organisatorische Maßnahmen (Artikel 32)

diese Geräte verwendet werden. Die Mitarbeiter müssen auch ausschließlich über sichere Geschäftsnachrichtensysteme kommunizieren und einen digitalen Homeofficeraum betreten, der durch ein starkes Passwort und / oder eine doppelte Authentifizierung geschützt ist. Das Einrichten von VPN-Netzwerk-Tools für professionelle Arbeitsabläufe trägt zur Sicherheit des Austauschs bei und verhindert, dass ein PC zum Einfallstor für Hacker wird.

- **Ausarbeitung eines Krisenkommunikationsplans:**

Im Falle eines Ransomware-Angriffs kann Ihre E-Mail- und Telefoninfrastruktur gestört sein. Es ist daher notwendig, Offline-Kommunikationskanäle vorzubereiten. Bewahren Sie gedruckte Kopien wesentlicher Mobiltelefonnummern auf (Computerlieferanten, Supportteams usw.).

- **Konsultieren Sie die MISP-Plattform vom CIRCL:**

CIRCL (Computer Incident Response Center Luxembourg) bietet einer privaten Organisation die Möglichkeit, sich mit MISP («Malware Information Sharing Platform») zu verbinden, einer Plattform zum Austausch von Informationen über vorhandene Malware und Bedrohungen. Ziel des MISP ist es, die Gegenmaßnahmen gegen gezielte Angriffe zu verbessern und Präventiv- und Detektionsmaßnahmen umzusetzen.

